

CompTIA SecAI+

Lab 2.1 — AI System Risks & Threat Modeling

Using GPT OSS 20B in Open WebUI

Lab Setup

In this lab you will identify security risks in AI systems and apply a threat-modeling framework to them. You will use the CSA MAESTRO framework, which organises AI-specific risk into seven layers, first by reasoning with the model and then by grounding it with live web search.

Before you begin, open Chat Controls (the sliders icon at the top-right of the chat), select Advanced Parameters, and apply these settings:

Parameter	Value
Max Tokens	2048
Every other parameter	Default (do not change)

Note: Do not change num_thread, num_batch, top_k, min_p, or any other advanced parameter — only Max Tokens should be changed. The others are not supported and cause a “property ... is unsupported” error.

Note: The free tier allows about 8,000 tokens per minute, and a chat resends its whole history on every message. Where a section keeps several prompts in one chat, the prompts ask for concise answers so they all fit.

Note: Model choice: use GPT OSS 20B for sections 2.1.1 and 2.1.2. For the web-search MAESTRO step (2.1.3), use models/gemini-2.5-flash or GPT OSS 120B — GPT OSS 20B tends to reshape MAESTRO into a generic flow instead of the seven layers.

Note: The seven MAESTRO layers are: Foundation Models, Data Operations, Agent Frameworks, Deployment & Infrastructure, Evaluation & Observability, Security & Compliance, and Agent Ecosystem.

2.1.1 Identify AI System Risks

Before building a formal threat model, it helps to understand how an AI system can fail at different levels. In this exercise you move through the MAESTRO layers, using the model to explore how problems appear at each one.

Note: All six prompts below run in the SAME chat, one per MAESTRO layer. Because a chat resends its history each time and the free tier limits tokens per minute, each prompt asks for a concise answer so all six fit in one chat. Web Search is not needed here — leave it OFF.

Step 1: Open Open WebUI and start a new chat with **GPT OSS 20B** (Web Search off).

Step 2: Enter the following prompt and note the response:

Prompt 1:

```
What kinds of issues could come from flaws or limitations in the base AI model itself? Keep your answer concise (2–3 sentences).
```

Insights: This is the Foundation Models layer — where intelligence begins. Hidden bias, poisoned training data, unsafe updates, or model leaks can ripple upward into every other layer.

Step 3: In the same chat, enter the following prompt and note the response:

Prompt 2:

```
An AI agent can call tools, APIs, or scripts on its own. What kinds of misuse or manipulation might happen through those connections? Keep your answer concise (2–3 sentences).
```

Insights: This is the Agent Frameworks layer, which defines how intent turns into action. Prompt injection, plugin abuse, and dependency hijacking are common threats here.

Step 4: In the same chat, enter the following prompt and note the response:

Prompt 3:

```
What could go wrong with the environment the agent runs in - its servers, containers, or network setup? Keep your answer concise (2–3 sentences).
```

Insights: This is the Deployment & Infrastructure layer — the servers, containers, and network the agent runs on, and the traditional infrastructure risks that apply there.

Step 5: In the same chat, enter the following prompt and note the response:

Prompt 4:

```
If the AI started acting unpredictably, what monitoring or feedback failures could allow that to go unnoticed? Keep your answer concise (2–3 sentences).
```

Insights: This is the Evaluation & Observability layer. Without logs, metrics, or audits, bad behaviour can persist indefinitely — you can't secure what you can't observe.

Step 6: In the same chat, enter the following prompt and note the response:

Prompt 5:

```
How could weak policies or missing compliance controls make an otherwise secure AI system risky for the organization? Keep your answer concise (2–3 sentences).
```

Insights: This is the Security & Compliance layer, which ensures technical security translates into organisational safety and data-protection compliance.

Step 7: In the same chat, enter the following prompt and note the response:

Prompt 6:

When multiple AI agents share a workspace or marketplace, what kinds of conflicts or manipulations could arise? Keep your answer concise (2–3 sentences).

Insights: This is the Agent Ecosystem — the outermost, social layer of agents. Collusion, misinformation loops, and untrusted integrations all live here.

Together, the seven layers form a map of AI-specific risk that goes beyond servers, networks, and users to include reasoning, autonomy, and collaboration between agents. (The Data Operations layer — data pipelines, storage, and RAG — is the seventh; the recap covers all seven.)

2.1.2 Apply a Threat Modeling Framework to AI

Applying a threat-modeling framework to AI means identifying how data, tools, and model behaviour could be misused, not just how software might be exploited. Here you compare unstructured discovery against a structured, layer-based analysis.

Step 1: Start a New Chat with **GPT OSS 20B**, enter the following prompt, and note the response:

Prompt 1:

You are a security analyst reviewing an AI content-moderation system. List all the ways this system could fail or be misused. Include both accidental errors and intentional manipulations.

Insights: Unstructured prompting lets the model think freely, but the results often overlap, skip whole domains (like infrastructure or observability), or mix system flaws with user behaviour.

Step 2: In the same chat, enter the following prompt and note the response:

Prompt 2:

Re-evaluate the same AI content-moderation system using the following framework.
For each layer below, identify: - One top threat - A short example scenario (<=25 words) - Impact (H/M/L) - Likelihood (H/M/L) - One key mitigation.
Layers: 1. Foundation Models 2. Data Operations 3. Agent Frameworks 4. Deployment & Infrastructure 5. Evaluation & Observability 6. Security & Compliance 7. Agent Ecosystem.
Return results as a concise Markdown table.

Insights: With a framework, the same model must think systematically. Instead of random risks, you get coverage across data, tooling, infrastructure, and governance, each tied to a specific mitigation.

Step 3: In the same chat, enter the following prompt and note the response:

Prompt 3:

Do any of these threats share a common cause across multiple layers?

Insights: One effective way to prioritise is consolidation — if a single underlying issue contributes to threats across several layers, address that issue first.

Q.1 Which causes were identified as affecting multiple layers of the threat model? (Select all that apply)

- A) Lack of user engagement
- B) Lack of version control
- C) Lack of robust security
- D) Lack of logging and monitoring

Step 4: In the same chat, enter the following prompt and note the response:

Prompt 4:

Which of the threats could occur without malicious intent? Which threats require an adversary?

Insights: Not all AI threats come from attackers. Emergent risks come from the model's own behaviour or design; adversarial risks are triggered by deliberate manipulation. Emergent risks need better design and monitoring; adversarial ones need stronger controls and validation.

Q.2 Which of the following from the threat model requires an adversary?

- A) Data Poisoning
- B) Overfitting

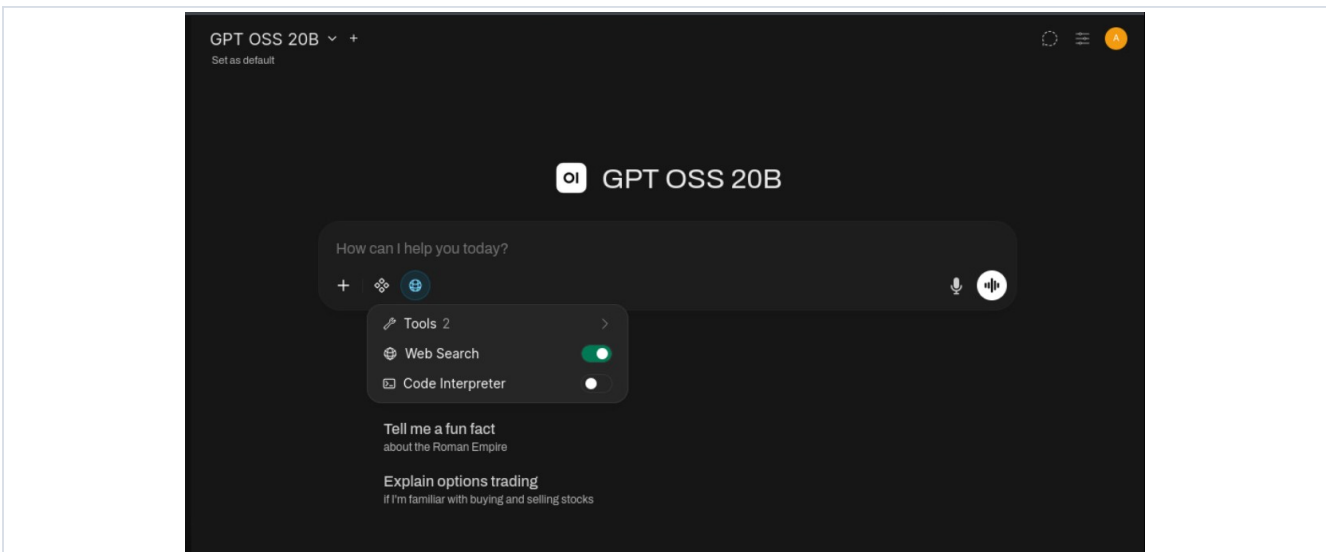
C) Bias in training data

D) Lack of real-time monitoring

2.1.3 Threat Modeling through the MAESTRO Framework (Web Search)

So far you have reasoned about MAESTRO with the model alone. Now you will ground it with live web search so the model pulls the framework from the source.

Note: Enable Web Search from the tools menu: select the + / tools icon beneath the chat box and turn Web Search ON (the globe turns blue).



Note: If the answer shows “No sources found”, the search found pages but couldn't extract their content. In Admin Settings → Web Search, turn Bypass Embedding and Retrieval ON and Save, then retry. (On Gemini this is safe; on GPT OSS 20B watch the token limit.)

Note: Use models/gemini-2.5-flash or GPT OSS 120B for this section. GPT OSS 20B fetches the pages but reshapes MAESTRO into a generic Model → Threats → Mitigations flow instead of the seven layers, which breaks the layer-based question below.

Step 1: Start a New Chat, turn Web Search ON, enter the following prompt, and note the response:

Prompt 1:

Use the MAESTRO framework from <https://cloudsecurityalliance.org> to model threats for a content moderation system.

Insights: The MAESTRO framework structures AI risk across its seven layers, linking technical flaws to broader ecosystem effects. Check that the answer actually lists the seven layers, not a generic flow.

Step 2: In the same chat, enter the following prompt and note the response:

Prompt 2:

Use the MAESTRO framework from <https://cloudsecurityalliance.org> to model threats for a voice assistant that processes and stores user commands.

Q.1 Which MAESTRO layer most directly addresses the risk of a voice assistant storing user commands without adequate encryption?

- A) Data Operations
- B) Agent Frameworks
- C) Security & Compliance
- D) Foundation Models

Q.2 Based on the MAESTRO output, which mitigation would best reduce multiple listed threats at once?

- A) Regular model retraining

- B) Encryption and strict access control
- C) User-education campaigns
- D) Expanding hardware capacity

Step 3: Turn Web Search OFF (this is a reasoning question, not a web lookup), then enter the following prompt and note the response:

Prompt 3:

Which of the threats could occur without malicious intent? Which threats require an adversary?

Insights: This prompt reasons over the threats already generated, so it does not need the web. Leaving Web Search on would run an unnecessary search on every message and waste tokens.

Note: Two web-search lessons worth noting: (1) “No sources found” means the answer is ungrounded — the model answers from memory and can invent details, so verify. (2) Even when sources are retrieved, a small model can still misrepresent the framework's structure — always check the output against the real seven MAESTRO layers.

Troubleshooting

Common situations in this lab, and what to do:

Situation	Do this
"No sources found" on a web-search prompt	The search found pages but couldn't extract content. In Admin Settings → Web Search, turn Bypass Embedding and Retrieval ON and Save, then retry. If it persists, the site may block fetching or the DDGS engine is rate-limited — retry later.
MAESTRO output shows a generic flow, not seven layers	The model reshaped the framework. Use models/gemini-2.5-flash or GPT OSS 120B, or pin the seven layers in the prompt (Foundation Models, Data Operations, Agent Frameworks, Deployment & Infrastructure, Evaluation & Observability, Security & Compliance, Agent Ecosystem).
Web search runs on every message	Web Search applies to every prompt while the globe is on. Turn it OFF for reasoning-only prompts so it doesn't search unnecessarily and waste tokens.
"Request too large ... tokens per minute (TPM): Limit 8000"	History plus the answer is over the per-minute limit. Start a New Chat, keep answers concise, or lower Max Tokens. On web-search steps, prefer Gemini for its larger context.
"property 'num_batch' / 'top_k' / ... is unsupported"	You customised a parameter that isn't supported. Open Chat Controls → Advanced Parameters and set it back to Default. Only Max Tokens should be changed.